

PS07 – Plan de Gestion de Incidentes de Seguridad de la Informacion

ID Documento: GOYA-PS07-001 **Version:** 1.0 **Fecha:** 2026-09-02 **Estado:** Borrador **Autor:** Oficial de Seguridad **Aprobado por:** Pendiente – Gerencia General **Clasificacion:** Confidencial **Proxima revision:** 2027-03-02

Version	Fecha	Autor	Cambios
1.0	2026-09-02	Oficial de Seguridad	Documento inicial

1. Objetivo y Alcance

1.1 Objetivo

Establecer el proceso integral de gestion de incidentes de seguridad de la informacion para Goya Ledger SpA en su calidad de Prestador de Servicios de Certificacion (PSC) bajo la Ley 19.799 y su reglamento DS 181/2002. Este documento cumple con el sub-proceso PS07 de la Guia de Acreditacion EA-103 v2.1, seccion 4.14, de la Entidad Acreditadora (Subsecretaria de Economia).

El plan garantiza que:

- Los eventos e incidentes de seguridad se detectan, reportan y evaluan de manera oportuna.
- Los incidentes se gestionan con procedimientos definidos que minimizan el impacto sobre los servicios de confianza.
- Se preserva la evidencia para investigacion forense y procedimientos legales.
- Las notificaciones regulatorias se realizan dentro de los plazos exigidos por ley.
- Los niveles de riesgo residual definidos en PS01 se mantienen mediante respuesta efectiva.

1.2 Alcance

El alcance cubre la totalidad de los servicios de confianza y la infraestructura de soporte:

- **Autoridad Certificadora (CA):** Emision de certificados X.509 para Firma Electronica Avanzada (FEA) con ML-DSA-65 (FIPS 204).

- **Autoridad de Sellado de Tiempo (TSA):** Sellos de tiempo RFC 3161 con precision NTP verificada.
- **Respondedor OCSP:** Consultas de estado de certificados en tiempo real (RFC 6960).
- **Autoridad de Registro (RA):** Verificacion de identidad presencial y remota (Smart-ID, ClaveUnica).
- **Infraestructura de soporte:** Nodos blockchain BFT (Rust/Actix-Web 4), almacenamiento RocksDB, red P2P con TLS 1.3.
- **Aplicacion de escritorio:** Tauri v2 (light client) para operaciones de firma.
- **Personal:** Todos los empleados, contratistas, y terceros con acceso a sistemas de Goya Ledger.

1.3 Relacion con otros sub-procesos

Sub-proceso	Relacion
PS01 (Gestion de Riesgos)	Los incidentes alimentan la actualizacion del registro de riesgos. Los controles de PS01 determinan las capacidades de deteccion y contencion
PS02 (Politica de Seguridad)	Los procedimientos de este plan implementan los objetivos de seguridad definidos en PS02
PS03 (Continuidad de Negocio)	Los procedimientos de recuperacion de PS03 se activan cuando un incidente escala a interrupcion de servicio
PS06 (Gestion de Claves)	Los procedimientos de compromiso de claves de PS06 se invocan para incidentes de categoria CAT-04

2. Marco Normativo

Norma	Aplicacion
Ley 19.799	Obligaciones del PSC en materia de seguridad e integridad de servicios
DS 181/2002	Reglamento de la Ley 19.799, requisitos operativos del PSC
Decreto 24/2019	Norma tecnica para FEA
EA-103 v2.1	Guia de acreditacion de PSC, seccion 4.14 (PS07)
Ley 21.459	Delitos informaticos: tipificacion de acceso ilicito, interceptacion, dano informatico, falsificacion informatica y fraude informatico
Ley 21.663	

Norma	Aplicacion
	Marco de Ciberseguridad: obligaciones de notificacion al CSIRT Nacional para operadores de servicios esenciales
Ley 19.628	Proteccion de datos personales: obligaciones de notificacion por brechas de datos
ISO/IEC 27002:2022	Control 5.24 (Planificacion y preparacion de gestion de incidentes), 5.25 (Evaluacion y decision sobre eventos), 5.26 (Respuesta a incidentes), 5.27 (Aprendizaje de incidentes), 5.28 (Recoleccion de evidencia)
ETSI EN 319 401	Requisitos generales para prestadores de servicios de confianza, seccion 7.11 (notificacion de incidentes)
ETSI TS 102 042	Requisitos de politica para CA, seccion 7.4.8 (gestion de incidentes)
NIS2 (EU 2022/2555)	Directiva de seguridad de redes e informacion, Art. 23 (notificacion de incidentes para entidades esenciales)
CIR 2025/2160	Reglamento de ejecucion sobre gestion de riesgos para TSP
NIST SP 800-61 Rev.3	Guia de manejo de incidentes de seguridad informatica

3. Taxonomia de Eventos e Incidentes de Seguridad

3.1 Definiciones

Evento de seguridad de la informacion (ISO 27002 5.24): Ocurrencia identificada en un sistema, servicio o red que indica una posible violacion de la politica de seguridad, falla de controles, o situacion previamente desconocida que puede ser relevante para la seguridad.

Incidente de seguridad de la informacion (ISO 27002 5.25): Uno o mas eventos de seguridad de la informacion no deseados o inesperados que tienen una probabilidad significativa de comprometer las operaciones del negocio y amenazar la seguridad de la informacion.

Debilidad de seguridad (ISO 27002 5.24): Condicion identificada en un sistema, servicio o red que, si es explotada, podria resultar en un evento o incidente de seguridad.

3.2 Categorias de incidentes

ID	Categoria	Descripcion	Ejemplos en contexto Goya Ledger
CAT-01	Acceso no autorizado	Acceso a sistemas,	

ID	Categoria	Descripcion	Ejemplos en contexto Goya Ledger
		datos o servicios sin autorizacion valida	Acceso a API sin token valido, violacion de ACL, acceso a nodo BFT no autorizado
CAT-02	Codigo malicioso / malware	Introduccion de software malicioso en la infraestructura	Compromiso de crate Rust, binario modificado, script malicioso en pipeline
CAT-03	Denegacion de servicio	Ataque o condicion que impide la disponibilidad de servicios	DDoS contra API Gateway, agotamiento de recursos en nodo BFT, saturacion de mempool
CAT-04	Compromiso de llave privada	Exposicion, robo o uso no autorizado de material criptografico	Compromiso de clave CA raiz/ intermedia, compromiso de clave de firma TSA, exposicion de clave OCSP
CAT-05	Fuga de datos / datos personales	Exposicion no autorizada de informacion confidencial o datos personales	Exfiltracion de registros de identidad RA, exposicion de datos de suscriptores, fuga de logs con PII
CAT-06	Falla de integridad	Corrupcion o alteracion no autorizada de datos o registros	Fork de blockchain, rotura de cadena de auditoria, corrupcion de RocksDB, alteracion de CRL
CAT-07	Fraude / suplantacion de identidad	Uso fraudulento de identidades o servicios del PSC	Emision de certificado a identidad falsa, suplantacion de operador RA, uso fraudulento de sello de tiempo
CAT-08	Vulnerabilidad tecnica explotada	Explotacion activa de una vulnerabilidad conocida o zero-day	Explotacion de CVE en dependencia Rust, vulnerabilidad en ML-DSA-65, bypass de validacion de entrada
CAT-09	Incidente fisico	Evento fisico que afecta la infraestructura	Acceso no autorizado a datacenter Fly.io, dano fisico a equipos, robo de dispositivos con material criptografico
CAT-10	Error humano con impacto en seguridad	Accion no intencional del personal que compromete la seguridad	Error de configuracion critica (RUST_BC_ENV), eliminacion accidental de registros de auditoria, despliegue de codigo con errores

3.3 Niveles de severidad

Nivel	Denominacion	Descripcion	Impacto en servicios de confianza	SLA respuesta	SLA resolucion
P1	Critico	Compromiso confirmado de material criptografico CA, emision masiva no autorizada de certificados, o perdida total de servicios	Suspension inmediata del servicio afectado. Riesgo de revocacion de acreditacion	< 15 minutos	< 4 horas
P2	Alto	Interrupcion de servicio CA/TSA/OCSP > 1 hora, emision unitaria no autorizada, compromiso de clave TSA/OCSP, brecha de datos personales	Degradacion significativa de servicios de confianza. Impacto en suscriptores	< 1 hora	< 24 horas
P3	Medio	Falla de integridad de auditoria, violacion de proceso RA, vulnerabilidad explotada sin compromiso confirmado, desviacion de NTP	Servicio operativo con integridad reducida. Requiere correccion antes de siguiente ciclo de auditoria	< 4 horas	< 72 horas
P4	Bajo	Intentos fallidos de acceso, desviaciones menores de politica, debilidades detectadas sin explotacion	Sin impacto directo en servicios. Requiere documentacion y seguimiento	< 24 horas	< 5 dias habiles

3.4 Criterios de clasificacion de severidad

Para asignar severidad, se evaluan los siguientes factores:

1. **Servicios afectados:** CA (peso 5), TSA (peso 4), OCSP (peso 4), RA (peso 3), infraestructura de soporte (peso 2).
 2. **Alcance:** Numero de suscriptores o certificados potencialmente afectados.
 3. **Confidencialidad del material comprometido:** Material criptografico CA > claves de servicio > datos personales > datos operativos.
 4. **Integridad de la cadena de confianza:** Afectacion a la cadena de certificacion X.509 o a la cadena de auditoria blockchain.
 5. **Reversibilidad:** Incidentes con consecuencias irreversibles (emision fraudulenta) se clasifican al menos como P2.
-

4. Procedimiento de Reporte de Eventos

4.1 Obligacion de reporte (ISO 27002 5.24)

Todo el personal de Goya Ledger, contratistas, terceros con acceso a sistemas, y usuarios de los servicios de confianza tienen la obligacion de reportar de manera inmediata cualquier evento de seguridad observado o sospechado. El incumplimiento de esta obligacion constituye una falta grave sujeta a procedimiento disciplinario conforme a PS02.

4.2 Canales de reporte

Canal	Uso	Disponibilidad
Email: security@goya.cl	Reporte general de eventos y debilidades	24/7 (monitoreado en horario laboral, alertas P1/P2 fuera de horario)
Telefono de emergencia	Eventos P1 y P2 fuera de horario laboral	24/7
Formulario interno (intranet)	Reporte estructurado de eventos	Horario laboral
Canal seguro (cifrado E2E)	Informacion clasificada o sensible	24/7

4.3 Punto de contacto

El **Oficial de Seguridad** es el punto de contacto primario para todos los reportes de eventos de seguridad. En su ausencia, el **Administrador PKI** asume la funcion de punto de contacto.

4.4 Contenido del reporte inicial

Todo reporte debe incluir como minimo:

1. Fecha y hora de deteccion del evento.
2. Nombre e identificacion del reportante.
3. Descripcion del evento observado.
4. Sistemas, servicios o datos afectados (CA, TSA, OCSP, RA, infraestructura).
5. Acciones tomadas antes del reporte (si aplica).
6. Evidencia disponible (capturas, logs, identificadores de transaccion).

4.5 Reporte de debilidades (ISO 27002 5.24)

Las debilidades de seguridad detectadas (vulnerabilidades, configuraciones inseguras, deficiencias en controles) se reportan a traves de los mismos canales pero no deben ser verificadas por el reportante. La verificacion de debilidades es responsabilidad exclusiva del equipo de respuesta para evitar explotacion accidental.

5. Equipo de Respuesta a Incidentes (CSIRT)

5.1 Estructura del equipo

Rol	Responsabilidad	Activacion por severidad	Contacto
Incident Commander (IC)	Direccion general de la respuesta. Toma de decisiones de contencion y comunicacion. Coordinacion con reguladores	P1, P2, P3	Oficial de Seguridad (security@goya.cl)
Security Analyst	Analisis tecnico, triage, investigacion forense, correlacion de logs	P1, P2, P3, P4	Administrador Sistemas (ops@goya.cl)
PKI Specialist	Operaciones CA, revocacion de certificados, publicacion de CRL, gestion de claves	P1, P2 (cuando involucra CA/TSA/OCSP)	Administrador PKI (pki@goya.cl)
Communications Lead	Comunicaciones externas, notificacion a suscriptores,	P1, P2	comms@goya.cl

Rol	Responsabilidad	Activacion por severidad	Contacto
Legal Advisor	comunicados publicos Notificaciones regulatorias, cadena de custodia, cumplimiento Ley 21.459, Ley 19.628	P1, P2	legal@goya.cl
Forensic Specialist	Preservacion de evidencia, analisis forense, recuperacion de datos	P1, P2 (activacion bajo demanda)	Contratado externamente (proveedor preseleccionado)

5.2 Matriz de escalamiento

Severidad	Nivel 1 (0-15 min)	Nivel 2 (15-60 min)	Nivel 3 (1-4 h)
P1	Security Analyst + IC	PKI Specialist + Legal + Communications	Gerencia General + Entidad Acreditadora
P2	Security Analyst + IC	PKI Specialist (si aplica)	Legal + Communications
P3	Security Analyst	IC (si requiere decision)	—
P4	Security Analyst (siguiente dia habil)	—	—

5.3 Guardia (on-call)

Se mantiene una rotacion semanal de guardia para respuesta fuera de horario laboral:

- **Primer respondedor:** Security Analyst de turno (cobertura 24/7 para P1/P2).
- **Escalamiento:** IC contactable 24/7 para activacion de equipo completo.
- **Calendario:** Publicado en sistema interno, actualizado mensualmente.

5.4 Soporte externo

Proveedor	Servicio	Activacion
Proveedor forense preseleccionado	Analisis forense avanzado, recuperacion de evidencia	P1, P2 (bajo demanda del IC)
CSIRT Nacional (Ley 21.663)	Coordinacion de respuesta nacional,	P1, P2 significativos

Proveedor	Servicio	Activacion
	inteligencia de amenazas	
Fly.io (proveedor de infraestructura)	Soporte de incidentes de plataforma, aislamiento de nodos	Incidentes de infraestructura
Asesor legal externo	Procedimientos judiciales, cumplimiento Ley 21.459	P1 con implicancias penales

6. Proceso de Gestion de Incidentes

El proceso sigue seis fases alineadas con ISO 27002:2022 (5.25, 5.26) y NIST SP 800-61 Rev.3.

6.1 Fase 1: Deteccion e Identificacion

6.1.1 Fuentes de deteccion

Fuente	Tipo	Eventos detectados
Logs estructurados JSON (LOG_FORMAT=json)	Automatica	Errores de autenticacion, violaciones de ACL, errores criptograficos, operaciones CA/TSA/OCSP
Cadena de auditoria blockchain	Automatica	Alteracion de registros de auditoria, gaps en secuencia, verify_audit_chain() failures
Metricas Fly.io	Automatica	Consumo anormal de CPU/memoria/disco, latencia elevada, reinicio de nodos
Rate limiting (RATE_LIMIT_RPS/RPM/RPH)	Automatica	Exceso de tasa de solicitudes, posible DDoS o abuso de API
Validacion ACL (enforce_acl)	Automatica	Intentos de acceso no autorizado a endpoints protegidos
Crypto boundary (cargo test --test crypto_boundary)	Periodica	Uso de primitivas criptograficas fuera del modulo pqc_crypto_module
Validacion NTP (NtpTimeSource::validate())	Automatica	Desviacion de fuente de tiempo > 1 segundo
Monitoreo de salud de nodos BFT	Automatica	Nodo caido, desincronizacion de consenso, fork detectado
Reportes del personal	Manual	Cualquier evento observado o sospechado

Fuente	Tipo	Eventos detectados
Notificaciones de suscriptores	Manual	Problemas de certificados, sospecha de uso fraudulento
Alertas de cargo-audit	Periodica	CVE en dependencias Rust

6.1.2 Umbrales de alerta

Metrica	Umbral P4	Umbral P3	Umbral P2	Umbral P1
Intentos fallidos de autenticacion	> 10/min	> 50/min	> 200/min	> 1000/min
Violaciones de ACL	> 5/hora	> 20/hora	> 100/hora	Cualquier acceso exitoso no autorizado a CA
Latencia API (p99)	> 2s	> 5s	> 30s o timeout	Servicio no responde
Desviacion NTP	> 500ms	> 1s	> 5s	Fuente NTP inalcanzable
Uso de disco en nodo	> 80%	> 90%	> 95%	100% (nodo degradado)
Errores de consenso BFT	> 1/hora	> 5/hora	Fork detectado	Consenso detenido
Fallas de verificacion de auditoria	1 warning	> 1 warning	1 failure	Chain break confirmado

6.1.3 Deteccion automatizada

El sistema genera alertas automaticas mediante:

1. **Pipeline de logs:** Los logs estructurados JSON emitidos por Actix-Web se procesan via Fly.io log drain. Eventos con nivel ERROR o patron de seguridad generan alerta.
2. **Health checks:** Endpoints /api/v1/health verifican estado de CA, TSA, OSCP, consenso BFT y sincronizacion NTP.
3. **Blockchain audit chain:** `verify_audit_chain()` ejecutado periodicamente detecta alteraciones o gaps en la cadena de auditoria inmutable.
4. **Rate limiting:** Los contadores RATE_LIMIT_RPS/RPM/RPH generan evento cuando se excede el umbral configurado.
5. **ACL enforcement:** `enforce_acl` registra y alerta sobre intentos de acceso no autorizado a operaciones criticas.

6.2 Fase 2: Evaluacion y Decision (ISO 27002 5.25)

6.2.1 Triage

El Security Analyst de turno realiza el triage inicial:

1. Verificar que el evento es real (descartar falso positivo).
2. Determinar si el evento constituye un incidente (aplicar definicion de seccion 3.1).
3. Asignar categoria (CAT-01 a CAT-10) segun seccion 3.2.
4. Asignar severidad (P1 a P4) segun criterios de seccion 3.3 y 3.4.
5. Asignar identificador unico: INC-YYYY-NNNN (ej: INC-2026-0001).
6. Registrar en sistema de seguimiento de incidentes.

6.2.2 Criterios de escalamiento

Se escala inmediatamente a P1 cuando:

- Hay evidencia de compromiso de clave privada CA (raiz o intermedia).
- Se confirma emision de certificado a identidad fraudulenta que afecta a multiples suscriptores.
- La cadena de auditoria blockchain presenta rotura confirmada.
- Hay perdida total de capacidad de emision, revocacion o sellado de tiempo.

Se escala a P2 cuando:

- Un servicio de confianza (CA, TSA, OCSP) no esta disponible por mas de 1 hora.
- Se confirma emision unitaria no autorizada.
- Se detecta brecha de datos personales de suscriptores.
- Se confirma explotacion activa de vulnerabilidad en produccion.

6.3 Fase 3: Contencion

6.3.1 Contencion inmediata (corto plazo)

Acciones ejecutables en minutos para limitar el dano:

Categoria	Accion de contencion inmediata
CAT-01 (Acceso no autorizado)	Revocar tokens/sesiones afectadas, bloquear IP origen, activar ACL restrictivo (ACL_MODE=strict)
CAT-02 (Malware)	Aislar nodo afectado de la red P2P, suspender despliegues, congelar pipeline de build
CAT-03 (DoS)	Activar rate limiting agresivo, bloquear rangos IP, activar proteccion Fly.io, escalar capacidad
CAT-04 (Compromiso de clave)	Suspender emision con clave afectada, publicar CRL de emergencia en < 1 hora, suspender responder OCSP para CA afectada, activar clave de respaldo via ceremonia de claves (PS06)

Categoria	Accion de contencion inmediata
CAT-05 (Fuga de datos)	Cerrar vector de exfiltracion, revocar accesos del vector, preservar logs de acceso
CAT-06 (Falla de integridad)	Detener escrituras en almacen afectado, activar modo lectura, preservar estado para analisis forense
CAT-07 (Fraude)	Suspender cuenta de operador RA involucrado, cuarentenar registros de identidad afectados, revocar certificados emitidos fraudulentamente
CAT-08 (Vulnerabilidad explotada)	Aplicar parche o workaround inmediato, aislar componente vulnerable, deshabilitar funcionalidad afectada
CAT-09 (Incidente fisico)	Notificar proveedor de datacenter, activar acceso remoto alternativo
CAT-10 (Error humano)	Revertir cambio (<code>git revert</code>), restaurar configuracion anterior, suspender cuenta si aplica

6.3.2 Contencion a largo plazo

Acciones para estabilizar el entorno antes de la erradicacion:

1. Rotar todas las credenciales y secretos potencialmente expuestos.
2. Aplicar parches de seguridad pendientes en componentes afectados.
3. Reconfigurar controles de acceso segun principio de minimo privilegio.
4. Activar monitoreo intensificado en servicios afectados.
5. Implementar controles compensatorios temporales hasta completar la erradicacion.

6.4 Fase 4: Erradicacion

1. **Analisis de causa raiz:** Identificar el origen del incidente mediante revision de logs estructurados, cadena de auditoria blockchain, y evidencia forense.
2. **Remediacion de vulnerabilidad:** Corregir la vulnerabilidad o debilidad explotada. Para dependencias Rust: actualizar crate, ejecutar `cargo-audit`, verificar con `cargo test`.
3. **Eliminacion de persistencia:** Verificar que el atacante no mantiene acceso por vias alternativas (backdoors, cuentas adicionales, claves comprometidas no rotadas).
4. **Hardening:** Aplicar controles adicionales para prevenir recurrencia, alineados con controles ISO 27002:2022 del registro de riesgos PS01.
5. **Verificacion de limpieza:** Ejecutar suite de pruebas completa (`cargo fmt --check && cargo clippy -- -D warnings && cargo test --lib`), verificar integridad de cadena de auditoria, confirmar estado limpio de todos los nodos BFT.

6.5 Fase 5: Recuperacion

1. **Restauracion de servicios:** Seguir el orden de restauracion definido en PS03: CA (prioridad 1) -> CRL (prioridad 1) -> OCSP (prioridad 1) -> TSA (prioridad 2) -> RA (prioridad 2).

2. **Verificacion de estado limpio:**
 - `verify_audit_chain()` retorna OK en todos los nodos.
 - `NtpTimeSource::validate()` confirma sincronizacion NTP.
 - Health check (`/api/v1/health`) confirma todos los servicios operativos.
 - Consenso BFT operativo con quorum completo.
3. **Emision de certificados de reemplazo:** Si se revocaron certificados durante la contencion, emitir reemplazos a suscriptores afectados previa re-verificacion de identidad.
4. **Monitoreo post-restauracion:** Periodo de monitoreo intensificado de 72 horas (P1/P2) o 24 horas (P3/P4) para detectar recurrencia.
5. **Comunicacion de restauracion:** Notificar a suscriptores afectados y reguladores que el servicio ha sido restaurado.

6.6 Fase 6: Post-Incidente (ISO 27002 5.27)

1. **Reporte post-incidente:** Completar dentro de 7 dias calendario (P1/P2) o 15 dias (P3/P4). Usar Plantilla 3 (seccion 12).
 2. **Analisis de causa raiz (RCA):** Reunion del equipo CSIRT para identificar causas tecnicas, procedimentales y organizacionales.
 3. **Lecciones aprendidas:** Documentar hallazgos y difundir al personal relevante.
 4. **Actualizacion del registro de riesgos PS01:** Revisar probabilidad e impacto de los riesgos asociados al incidente. Agregar nuevos riesgos si se identificaron amenazas no contempladas.
 5. **Mejora de controles:** Implementar acciones correctivas y preventivas con plazo y responsable definidos.
 6. **Actualizacion de procedimientos:** Modificar este plan, runbooks, y configuraciones de alerta segun hallazgos.
 7. **Briefing a partes interesadas:** Informar a Gerencia General, y a la Entidad Acreditadora si el incidente fue P1/P2.
-

7. Recoleccion y Preservacion de Evidencia (ISO 27002 5.28)

7.1 Principios

La recoleccion y preservacion de evidencia se rige por:

- **Admisibilidad legal:** La evidencia debe ser admisible en procedimientos judiciales bajo Ley 19.799 Art. 5 (equivalencia funcional del documento electronico) y Ley 21.459 (delitos informaticos).
- **Integridad:** La evidencia no debe ser alterada durante su recoleccion, transporte o almacenamiento.
- **Cadena de custodia:** Toda manipulacion de evidencia debe quedar registrada con responsable, fecha/hora, y accion realizada.
- **Compleitud:** Se recolecta toda la evidencia relevante, no solo la que soporta una hipotesis particular.

7.2 Procedimiento de recoleccion

1. Identificacion de fuentes de evidencia:

- Logs estructurados JSON del servidor Actix-Web.
- Cadena de auditoria blockchain (RocksDB).
- Registros de Fly.io (log drain, metricas de infraestructura).
- Configuraciones de sistema (STORAGE_BACKEND, ACL_MODE, SIGNING_ALGORITHM).
- Estado de la base de datos RocksDB (snapshots).
- Trafico de red capturado (si monitoreo estaba activo).
- Registros de acceso fisico (si aplica).

2. Adquisicion:

- Crear snapshot del nodo afectado antes de cualquier accion de contencion cuando sea posible.
- Exportar logs relevantes con marcas de tiempo UTC.
- Generar hash SHA-256 de cada pieza de evidencia inmediatamente despues de la adquisicion.
- Sellar temporalmente la evidencia usando el servicio TSA propio (sello RFC 3161) para establecer existencia en momento determinado.

3. Documentacion:

- Registrar en el formulario de cadena de custodia: pieza de evidencia, hash SHA-256, sello de tiempo TSA, responsable de recoleccion, ubicacion de almacenamiento.

7.3 Cadena de custodia

Campo	Descripcion
ID Evidencia	Identificador unico: EV-INC-YYYY-NNNN-SEQ
Descripcion	Que contiene la evidencia
Hash SHA-256	Hash del archivo o conjunto de datos
Sello TSA	Token RFC 3161 del sello de tiempo
Recolectado por	Nombre y rol del responsable
Fecha/hora recoleccion	Timestamp UTC
Ubicacion almacenamiento	Ruta o sistema donde se almacena
Accesos posteriores	Registro de cada acceso con fecha, persona, y motivo

7.4 Almacenamiento de evidencia

- La evidencia se almacena en repositorio cifrado separado del entorno de produccion.
- Acceso restringido al IC, Security Analyst, y Forensic Specialist.
- Periodo de retencion minimo: 5 anos (alineado con prescripcion de Ley 21.459).
- Copias de respaldo de la evidencia en ubicacion geografica separada.

7.5 Herramientas forenses

Herramienta	Proposito
SHA-256 (via <code>pqc_crypto_module</code>)	Hashing de integridad de evidencia
TSA RFC 3161 (servicio propio)	Sellado temporal de evidencia
<code>verify_audit_chain()</code>	Verificacion de integridad de cadena de auditoria
RocksDB backup/restore	Snapshot de base de datos para analisis
Fly.io log export	Exportacion de logs de infraestructura
<code>cargo-audit</code>	Verificacion de vulnerabilidades en dependencias

8. Notificaciones Regulatorias

8.1 Entidad Acreditadora (Subsecretaria de Economia)

Tipo de incidente	Plazo de notificacion	Formato
P1 (Critico)	24 horas desde la deteccion	Correo electronico a <code>oficinadepartesgd@economia.cl</code> con Plantilla 4 (seccion 12)
P2 (Alto)	24 horas desde la deteccion	Correo electronico a <code>oficinadepartesgd@economia.cl</code> con Plantilla 4
P3 con impacto en integridad de certificados	72 horas desde la deteccion	Correo electronico con Plantilla 4 (version resumida)

Contenido de la notificacion:

1. Identificacion del PSC y numero de acreditacion.
2. Fecha y hora de deteccion.
3. Descripcion del incidente y servicios afectados.
4. Impacto estimado (suscriptores, certificados).
5. Acciones de contencion tomadas.
6. Plan de remediacion y plazos.

8.2 CSIRT Nacional (Ley 21.663)

Goya Ledger, como operador de servicios esenciales en infraestructura digital, notifica al CSIRT Nacional:

Etapas	Plazo	Contenido
Alerta temprana	24 horas desde deteccion	Si el incidente es sospechosamente malicioso o tiene impacto transfronterizo
Notificacion de incidente	72 horas desde deteccion	Severidad, impacto, IoCs, evaluacion inicial
Reporte intermedio	A solicitud del CSIRT	Actualizacion de estado
Reporte final	1 mes despues de la notificacion	Causa raiz, medidas de mitigacion, impacto final

8.3 Titulares afectados (Ley 19.628)

Cuando el incidente involucra fuga o acceso no autorizado a datos personales de suscriptores:

- Notificacion sin demora injustificada a los titulares afectados.
- Contenido: naturaleza de la brecha, datos afectados, medidas tomadas, recomendaciones al titular, punto de contacto.
- Canal: correo electronico registrado del suscriptor + notificacion en portal.

8.4 NIS2 Art. 23 (operaciones EU via Estonia)

Para la entidad registrada en Estonia como TSP bajo eIDAS:

Etapas	Plazo	Destinatario	Contenido
Alerta temprana	24 horas desde deteccion	CSIRT nacional (RIA Estonia) + ENISA	Si el incidente es sospechosamente malicioso o transfronterizo
Notificacion de incidente	72 horas desde deteccion	CSIRT nacional + ENISA	Severidad, impacto, IoCs, evaluacion inicial
Reporte intermedio	A solicitud	CSIRT nacional	Actualizacion de estado
Reporte final	1 mes despues de notificacion	CSIRT nacional + ENISA	Causa raiz, mitigacion, impacto transfronterizo

Para incidentes significativos que afectan a usuarios del servicio de confianza:

- Notificar a usuarios afectados sin demora indebida (Art. 23(1)).
- Incluir guia de mitigacion en la notificacion.

8.5 Registro de notificaciones

Toda notificacion regulatoria se registra con:

- Destinatario y canal utilizado.

- Fecha y hora de envio.
 - Contenido enviado (copia).
 - Acuse de recibo (cuando disponible).
 - Responsable del envio.
-

9. Sistema de Gestion de Incidentes (Implementacion)

9.1 Arquitectura actual

Goya Ledger opera con la siguiente infraestructura de deteccion y gestion de incidentes:

Capa de generacion de eventos: - Servidor Actix-Web 4 con logging estructurado JSON (`LOG_FORMAT=json`). - Eventos de auditoria registrados en cadena blockchain inmutable (RocksDB). - Rate limiting con contadores `RATE_LIMIT_RPS/RPM/RPH`. - ACL enforcement via `enforce_acl` con registro de violaciones. - Validacion criptografica con `SigningAlgorithm` y `verify_signature()`.

Capa de recoleccion: - Fly.io log drain para centralizacion de logs de todos los nodos. - Metricas de infraestructura Fly.io (CPU, memoria, disco, red). - Health checks periodicos via `/api/v1/health`.

Capa de deteccion: - Umbrales configurados en rate limiting y ACL. - `verify_audit_chain()` para integridad de cadena de auditoria. - `NtpTimeSource::validate()` para desviacion de fuente de tiempo. - cargo-audit para vulnerabilidades en dependencias.

Capa de registro y seguimiento: - Incidentes registrados con ID `INC-YYYY-NNNN` en sistema interno. - Cadena de auditoria blockchain proporciona registro inmutable de acciones de respuesta. - `ApiResponse<T>` con trace ID para correlacion de eventos.

9.2 Pipeline de alertas

Evento → Log JSON (Actix-Web) → Fly.io Log Drain → Filtro de patrones

telefono)

(triage)

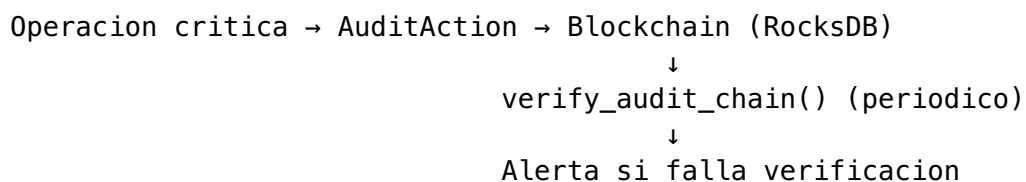
incidente

↓
Alerta (email/

↓
Security Analyst

↓
Registro de

Para eventos de auditoria blockchain:



9.3 Metricas por incidente

Para cada incidente se registran:

Metrica	Descripcion
Tiempo de deteccion (TTD)	Desde ocurrencia hasta deteccion
Tiempo de respuesta (TTR)	Desde deteccion hasta inicio de contencion
Tiempo de contencion (TTC)	Desde inicio hasta completar contencion
Tiempo de resolucion (MTTR)	Desde deteccion hasta restauracion completa del servicio
Suscriptores afectados	Numero de suscriptores impactados
Certificados afectados	Numero de certificados revocados, suspendidos o emitidos fraudulentamente
Costo estimado	Impacto financiero estimado
Notificaciones enviadas	Reguladores y titulares notificados

9.4 Mejoras planificadas

Mejora	Prioridad	Plazo estimado
SIEM dedicado con correlacion automatica de eventos	Alta	2027-Q2
Integracion de alertas con sistema de ticketing estructurado	Media	2027-Q1
Dashboard de metricas de incidentes en tiempo real	Media	2027-Q2
Playbooks automatizados para contencion de P1 (revocacion automatica, CRL de emergencia)	Alta	2027-Q1
Integracion con feeds de	Baja	2027-Q3

Mejora	Prioridad	Plazo estimado
inteligencia de amenazas (CSIRT Nacional, MISP)		

10. Mejora Continua

10.1 Revision post-incidente

Despues de cada incidente P1, P2 o P3 se realiza una reunion de revision:

- **Plazo:** Dentro de 5 dias habiles del cierre del incidente.
- **Participantes:** Equipo CSIRT involucrado, responsable del area afectada.
- **Producto:** Reporte post-incidente (Plantilla 3) con acciones correctivas y preventivas.
- **Seguimiento:** Las acciones se registran con responsable y plazo. Se verifican en la siguiente reunion de revision.

10.2 Analisis de tendencias

Trimestralmente se genera un informe de tendencias que incluye:

- Numero de eventos e incidentes por categoria (CAT-01 a CAT-10).
- Distribucion por severidad (P1 a P4).
- Tendencias temporales (aumento/disminucion por categoria).
- Fuentes de deteccion mas efectivas.
- Tiempo promedio de deteccion y resolucion.
- Incidentes recurrentes (misma causa raiz).

10.3 Indicadores clave de desempeno (KPI)

KPI	Formula	Meta
MTTD (Mean Time to Detect)	Promedio de TTD por periodo	P1: < 15 min, P2: < 1h, P3: < 4h
MTTR (Mean Time to Resolve)	Promedio de MTTR por periodo	P1: < 4h, P2: < 24h, P3: < 72h
Tasa de incidentes por categoria	Incidentes CAT-XX / total incidentes	Sin meta fija; para analisis de tendencias
Tasa de recurrencia	Incidentes con misma causa raiz / total	< 5%
Cumplimiento de SLA de respuesta	Incidentes dentro de SLA / total	> 95%
Cumplimiento de notificacion regulatoria	Notificaciones dentro de plazo legal / total requeridas	100%

KPI	Formula	Meta
Eficacia de deteccion automatica	Incidentes detectados automaticamente / total	> 80%
Ejercicios completados	Ejercicios realizados / ejercicios planificados	100%

10.4 Alimentacion al ciclo de riesgos PS01

Los resultados del analisis de tendencias y las lecciones aprendidas se incorporan a la revision anual del registro de riesgos de PS01:

1. Incidentes que materialicen un riesgo existente ajustan la probabilidad estimada.
2. Incidentes que revelen amenazas nuevas generan nuevas entradas en el registro.
3. La eficacia de los controles se evalua en funcion de su capacidad de prevenir, detectar y contener incidentes.
4. Los niveles de riesgo residual se recalculan post-incidente.

11. Coherencia con PS01

11.1 Mapeo de riesgos PS01 a categorias de incidentes y procedimientos de respuesta

ID Riesgo PS01	Descripcion del riesgo	Categoria de incidente	Severidad esperada	Contencion primaria	Control ISO 27002
R-01	Robo de clave privada CA raiz	CAT-04	P1	Suspender CA, CRL emergencia, ceremonia de clave de respaldo	A.8.24
R-02	Robo de clave privada CA intermedia	CAT-04	P1/P2	Revocar certificados, CRL emergencia	A.8.24, A.8.2
R-03	Intrusion a nodos BFT	CAT-01	P2	Aislar nodo, ACL strict, revision de accesos	A.8.20, A.8.5
R-04	DDoS contra API Gateway	CAT-03	P2/P3	Rate limiting agresivo, proteccion Fly.io	A.8.26
R-05	Emision no autorizada por administrador	CAT-07	P1/P2	Suspender cuenta, cuarentenar certificados	A.5.3, A.8.15
R-06	Certificado emitido a identidad falsa	CAT-07	P1/P2	Revocar certificado, suspender RA, investigar proceso	A.5.17, A.8.15
R-07	Falla de sincronizacion NTP en TSA	CAT-06	P2/P3	Suspender TSA, verificar sellos emitidos	A.8.17
R-08		CAT-06	P1		A.8.24

ID Riesgo PS01	Descripcion del riesgo	Categoria de incidente	Severidad esperada	Contencion primaria	Control ISO 27002
	Manipulacion de consenso BFT			Detener nodos, verificar cadena, restaurar de checkpoint	
R-09	Fork de cadena	CAT-06	P2	Identificar fork, detener escrituras, resolver con consenso	A.8.25
R-10	Harvest-now-decrypt-later sobre FES	CAT-08	P3	Acelerar migracion a ML-DSA-65, notificar suscriptores FES	A.8.24
R-13	Vulnerabilidad en ML-DSA-65	CAT-08	P1/P2	Suspender FEA, activar firma alternativa, parchar	A.8.28, A.8.8
R-14	Phishing contra operador PKI	CAT-01	P2/P3	Revocar credenciales, revisar acciones del operador	A.6.3, A.8.5
R-15	Compromiso de dependencia Rust	CAT-02	P2	Congelar despliegues, revertir crate, cargo-audit	A.8.25, A.5.21
R-16	Corrupcion de RocksDB	CAT-06	P2/P3	Restaurar de backup, verificar integridad	A.8.13
R-17	Error de configuracion critica	CAT-10	P3	Revertir configuracion, validar con RUST_BC_ENV=production	A.8.9
R-18	Despliegue de codigo con errores	CAT-10	P3	Revertir despliegue, ejecutar suite de pruebas	A.8.25, A.8.31
R-19	Eliminacion accidental de registros de auditoria	CAT-06/ CAT-10	P2/P3	Restaurar de backup, verificar audit chain	A.5.33
R-23	Explotacion de CVE en dependencia	CAT-08	P2/P3	Parchar, actualizar crate, verificar explotacion	A.8.8
R-26	Exfiltracion de datos por personal	CAT-05	P2	Revocar accesos, preservar evidencia, notificar titulares	A.5.10, A.6.2
R-28	Error en verificacion de identidad RA	CAT-07/ CAT-10	P3	Suspender RA, auditar verificaciones recientes	A.5.17, A.8.15
R-32	Bug en logica de consenso o firma	CAT-06/ CAT-08	P2	Detener nodo, revertir codigo, verificar emision	A.8.28, A.8.25
R-35	Violacion de Ley 19.628	CAT-05	P2	Cerrar vector, notificar titulares y autoridad	A.5.34, A.8.11

ID Riesgo PS01	Descripcion del riesgo	Categoria de incidente	Severidad esperada	Contencion primaria	Control ISO 27002
	por fuga de datos				

11.2 Verificacion de riesgo residual

Los procedimientos de respuesta de este plan estan disenados para mantener los niveles de riesgo residual definidos en PS01. La verificacion se realiza mediante:

1. **Post-incidente:** Cada incidente P1/P2 incluye una evaluacion de si el riesgo residual del riesgo PS01 asociado se mantuvo dentro del nivel aceptado. Si no, se activa un ciclo de tratamiento de riesgo adicional.
2. **Revision trimestral:** El analisis de tendencias de incidentes se contrasta con los niveles de riesgo residual de PS01. Tendencias al alza en una categoria pueden requerir recalculation.
3. **Revision anual:** El ejercicio anual de revision de riesgos PS01 incorpora el historial de incidentes como entrada para re-estimar probabilidades e impactos.

12. Plantillas de Reporte de Incidentes

12.1 Plantilla 1: Reporte Inicial de Evento

=====

REPORTE INICIAL DE EVENTO DE SEGURIDAD

=====

Fecha del reporte: ____/____/____

Hora del reporte: ____:____ (UTC)

DATOS DEL REPORTANTE

Nombre completo: _____

Cargo/Rol: _____

Email: _____

Telefono: _____

DESCRIPCION DEL EVENTO

Fecha de deteccion: ____/____/____

Hora de deteccion: ____:____ (UTC)

Metodo de deteccion: [] Automatico (alerta de sistema)

[] Manual (observacion directa)

[] Notificacion de tercero

[] Otro: _____

Descripcion del evento:

Sistemas/Servicios afectados:

- ☐ CA (Autoridad Certificadora)
- ☐ TSA (Sellado de Tiempo)
- ☐ OCSP (Estado de Certificados)
- ☐ RA (Registro de Identidad)
- ☐ Infraestructura BFT
- ☐ Red P2P
- ☐ API Gateway
- ☐ Almacenamiento (RocksDB)
- ☐ Otro: _____

Impacto observado:

Acciones tomadas antes del reporte:

Evidencia disponible:

- ☐ Logs del sistema
- ☐ Capturas de pantalla
- ☐ Trace IDs: _____
- ☐ Otra: _____

=====

USO INTERNO (completar por Security Analyst)

=====

Evento recibido por: _____

Fecha/hora recepcion: ____/____/____ ____:____ (UTC)

Clasificacion inicial:

Categoria: ☐ CAT-01 ☐ CAT-02 ☐ CAT-03 ☐ CAT-04
☐ CAT-05 ☐ CAT-06 ☐ CAT-07 ☐ CAT-08
☐ CAT-09 ☐ CAT-10

Severidad: ☐ P1 ☐ P2 ☐ P3 ☐ P4

Decision: ☐ Escalar a incidente (ID: INC-_____-_____)
☐ Registrar como evento (sin escalamiento)
☐ Falso positivo (justificacion: _____)

=====

12.2 Plantilla 2: Reporte de Incidente

=====

REPORTE DE INCIDENTE DE SEGURIDAD

=====

ID Incidente: INC-_____-_____

Fecha de apertura: ____/____/____

Incident Commander: _____

Estado: ☐ Abierto ☐ En contencion

[] Cerrado

Servicios afectados: _____

Fecha/Hora (UTC)	Evento
	Evento detectado
	Reporte recibido
	Triage completado
	Contencion iniciada
	Contencion completada
	Erradicacion iniciada
	Erradicacion completada
	Servicio restaurado
	Monitoreo post-restauracion inicia
	Incidente cerrado

Descripcion del incidente:

Vector de ataque / causa inmediata:

Indicadores de compromiso (IoCs):

- IPs: _____
- Hashes: _____
- Trace IDs: _____
- Otros: _____

IMPACTO

Suscriptores afectados: _____
Certificados revocados: _____
Certificados emitidos sin autorizacion: _____
Sellos de tiempo afectados: _____
Datos personales expuestos: [] Si [] No
Interrupcion de servicio: _____ horas
Impacto financiero estimado: USD _____

ACCIONES DE CONTENCION

ACCIONES DE ERRADICACION

ACCIONES DE RECUPERACION

EVIDENCIA RECOLECTADA

ID Evidencia	Descripcion	Hash SHA-256	
Sello TSA			
-----	-----	-----	-----
EV-INC-YYYY-NNNN-001			
EV-INC-YYYY-NNNN-002			

NOTIFICACIONES REALIZADAS

Destinatario	Fecha/Hora	Canal	Responsable	
-----	-----	-----	-----	
Entidad Acreditadora				
CSIRT Nacional				
Suscriptores afectados				
RIA Estonia / ENISA				

METRICAS

TTD (deteccion): _____ minutos
TTR (respuesta): _____ minutos
TTC (contencion): _____ minutos
MTTR (resolucion): _____ horas

Firma Incident Commander: _____ Fecha: _____

=====

12.3 Plantilla 3: Reporte Post-Incidente

=====

REPORTE POST-INCIDENTE

=====

ID Incidente: INC-____-____

Fecha del reporte: ____/____/____

Autor: _____

RESUMEN EJECUTIVO

ANALISIS DE CAUSA RAIZ

Causa tecnica:

Causa procedimental:

Causa organizacional:

Diagrama de causa (5 porques):

1. Por que ocurrio? _____

2. Por que? _____

3. Por que? _____

4. Por que? _____

5. Por que (causa raiz)? _____

EVALUACION DE RESPUESTA

Que funciono bien:

Que no funciono o se puede mejorar:

SLA cumplidos: ☐ Si ☐ No (detalle: _____)

IMPACTO EN RIESGO RESIDUAL PS01

Riesgo PS01 asociado: R-____

Nivel de riesgo residual pre-incidente: _____

Nivel de riesgo residual post-incidente: _____

Justificacion del cambio:

ACCIONES CORRECTIVAS

#	Accion	Responsable	Plazo	Estado
1				
2				
3				

ACCIONES PREVENTIVAS

#	Accion	Responsable	Plazo	Estado
1				
2				
3				

ACTUALIZACIONES REQUERIDAS

- ☐ Registro de riesgos PS01
- ☐ Politica de seguridad PS02
- ☐ Plan de continuidad PS03
- ☐ Plan de gestion de claves PS06
- ☐ Plan de gestion de incidentes PS07 (este documento)
- ☐ Configuraciones de alertas
- ☐ Runbooks operativos
- ☐ Otro: _____

Descripcion de actualizaciones:

LECCIONES APRENDIDAS

Aprobado por IC: _____ Fecha: _____

Revisado por Oficial de Seguridad: _____ Fecha: _____

=====

12.4 Plantilla 4: Notificacion a Entidad Acreditadora

=====

NOTIFICACION DE INCIDENTE DE SEGURIDAD

Prestador de Servicios de Certificacion

=====

De: Goya Ledger SpA
Oficial de Seguridad
security@goya.cl

Para: Subsecretaria de Economia
Entidad Acreditadora
oficinadepartesgd@economia.cl

Fecha: ____/____/____

Ref: Notificacion de incidente conforme a Ley 19.799
y Guia EA-103 v2.1

Senores,

Por medio de la presente, Goya Ledger SpA, en su calidad de
Prestador de Servicios de Certificacion acreditado, notifica
el siguiente incidente de seguridad:

1. IDENTIFICACION

ID Incidente: INC-____-____
Numero de acreditacion: _____
Fecha de deteccion: ____/____/____:____ (UTC)
Severidad: P__ (____)

2. DESCRIPCION DEL INCIDENTE

3. SERVICIOS AFECTADOS

☐ Autoridad Certificadora (CA)
☐ Autoridad de Sellado de Tiempo (TSA)
☐ Respondedor OCSP
☐ Autoridad de Registro (RA)

Detalle: _____

4. IMPACTO

Suscriptores potencialmente afectados: _____
Certificados afectados: _____
Interrupcion de servicio: ☐ Si (____ horas)
☐ No
Datos personales comprometidos: ☐ Si ☐ No

5. ACCIONES TOMADAS

a) Contencion: _____
b) Erradicacion (si completada): _____
c) Estado actual del servicio:
☐ Operativo ☐ Parcialmente operativo ☐ Suspendido

6. PLAN DE REMEDIACION

Plazo estimado de resolucion completa: ____/____/____

7. PROXIMA COMUNICACION

Se enviara actualizacion el ____/____/____ o antes
si hay cambios significativos.

Atentamente,

Oficial de Seguridad
Goya Ledger SpA
security@goya.cl

=====

13. Plan de Pruebas

13.1 Ejercicios de mesa (tabletop)

- **Frecuencia:** Trimestral.
- **Participantes:** Equipo CSIRT completo.
- **Formato:** Simulacion narrativa de un escenario de incidente. El facilitador presenta el escenario y los participantes describen las acciones que tomarian en cada fase.
- **Escenarios tipo:**
 - Compromiso de clave privada CA intermedia (CAT-04, P1).
 - DDoS sostenido contra API Gateway con perdida de servicio OCSP (CAT-03, P2).
 - Emision de certificado a identidad fraudulenta detectada por suscriptor (CAT-07, P2).
 - Fuga de datos personales de suscriptores por error de configuracion (CAT-05/CAT-10, P2).
 - Fork de blockchain con divergencia de cadena de auditoria (CAT-06, P2).

13.2 Simulacros tecnicos

- **Frecuencia:** Semestral.
- **Participantes:** Equipo CSIRT + personal tecnico relevante.
- **Formato:** Ejecucion real de procedimientos de respuesta en entorno de prueba.
- **Actividades:**
 - Revocacion de certificado y publicacion de CRL de emergencia.
 - Aislamiento de nodo BFT y verificacion de continuidad de consenso.
 - Restauracion de servicio desde backup (alineado con PS03).
 - Ejecucion completa del proceso de notificacion regulatoria (sin envio real).
 - Recoleccion de evidencia y verificacion de cadena de custodia.

13.3 Criterios de exito

Criterio	Meta
Todos los roles del CSIRT son activados dentro de SLA	100%
El equipo identifica correctamente la categoria y severidad	> 90%
Las acciones de contencion se ejecutan segun procedimiento	100%
La cadena de custodia de evidencia se completa sin errores	100%
Las notificaciones regulatorias se preparan dentro de plazo	100%
Los servicios se restauran dentro del SLA de resolucion	> 95%

13.4 Documentacion de resultados

Cada ejercicio produce un reporte que incluye:

1. Escenario ejecutado y fecha.
2. Participantes.
3. Cronologia de acciones tomadas.
4. Evaluacion contra criterios de exito.
5. Hallazgos y areas de mejora.
6. Acciones correctivas con responsable y plazo.

Los resultados alimentan el ciclo de mejora continua (seccion 10) y se conservan como evidencia para la auditoria de la Entidad Acreditadora.

14. Referencias

Referencia	Titulo
Ley 19.799	Sobre documentos electronicos, firma electronica y servicios de certificacion
DS 181/2002	Reglamento de la Ley 19.799
Decreto 24/2019	Aprueba norma tecnica para Firma Electronica Avanzada
EA-103 v2.1	Guia de acreditacion de Prestadores de Servicios de Certificacion
Ley 21.459	Establece normas sobre delitos informaticos
Ley 21.663	Ley Marco de Ciberseguridad
Ley 19.628	Sobre proteccion de la vida privada (datos personales)
ISO/IEC 27002:2022	Seguridad de la informacion, ciberseguridad y proteccion de la privacidad – Controles de seguridad de la informacion

Referencia	Titulo
ETSI EN 319 401	General Policy Requirements for Trust Service Providers
ETSI TS 102 042	Policy requirements for certification authorities issuing qualified certificates
NIS2 (EU 2022/2555)	Directive on measures for a high common level of cybersecurity
CIR 2025/2160	Implementing regulation on risk management for TSPs
NIST SP 800-61 Rev.3	Computer Security Incident Handling Guide
GOYA-PS01-001	PS01 – Plan de Gestion de Riesgos y Amenazas
GOYA-PS02-001	PS02 – Politica de Seguridad de la Informacion
GOYA-PS03-001	PS03 – Plan de Continuidad de Negocio
GOYA-PS06-001	PS06 – Plan de Gestion de Claves
GOYA-IRP-001	Incident Response Plan (documento operativo interno)